



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CISA Warns of Actively Exploited Joomla JCE Flaw Allowing PHP Code Execution

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CISA Warns of Actively Exploited Joomla JCE Flaw Allowing PHP Code Execution - Vulnerability Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CISA Warns of Actively Exploited Joomla JCE Flaw Allowing PHP Code Execution

1. Executive Summary

CISA added CVE-2026-48907, an actively exploited improper access control vulnerability in Widget Factory Joomla Content Editor (JCE), to the Known Exploited Vulnerabilities catalog on 2026-06-16. The flaw allows unauthenticated attackers to create or import JCE editor profiles that permit PHP-capable file upload behavior, enabling PHP code upload and execution on vulnerable Joomla sites. CISA lists the required remediation due date for covered federal systems as 2026-06-19 and identifies the weakness as CWE-284.

Lost Boys Cyber assesses this issue as a critical internet-facing CMS exposure, not a routine plugin update. JCE is a high-adoption Joomla editor extension, the vulnerable endpoint is reachable before authentication, public exploit code and automated exploitation have been reported, and vendor guidance states that patching closes the entry point but does not remove already dropped profiles or webshells. Organizations operating Joomla for public web, customer portals, manufacturing partner portals, support knowledge bases, or supplier-facing content should prioritize emergency inventory, upgrade, and compromise assessment.

The immediate defensive priority is to update JCE to 2.9.99.6 where possible, or at minimum 2.9.99.5 plus vendor-recommended mitigations for older environments; inspect JCE profiles for rogue entries; review web logs for unauthenticated requests to the profile import task; and hunt writable Joomla paths such as images, media, tmp, media/system/js, and libraries/joomla for PHP droppers and webshell artifacts. Treat any confirmed malicious profile or webshell as a full web-server compromise requiring credential rotation, persistence review, and content integrity validation.

Priority	Defensive decision	Rationale
Critical	Patch or isolate vulnerable Joomla/JCE instances within 24 hours	CISA KEV listing and vendor-confirmed active exploitation indicate real-world weaponization.
Critical	Perform compromise assessment before declaring remediation complete	Vendor states updates do not remove profiles or files left by attackers.
High	Hunt for rogue JCE profiles and PHP webshells in writable directories	Exploitation chain depends on profile manipulation and executable upload.
Medium	Improve CMS governance and plugin inventory	Broad CMS plugin exposure makes otherwise low-profile sites viable initial access points.

2. Intelligence Requirement

Lost Boys Cyber reviewed this intake to answer the following intelligence requirement:

Requirement	Assessment focus	Decision supported
What is exposed?	Joomla sites running JCE 1.0.0 through 2.9.99.4, especially internet-facing instances.	Emergency asset discovery and patch prioritization.
What can an attacker do?	Create or import JCE profiles and use the resulting upload permissions to place executable PHP content.	Incident severity and containment scope.
What evidence should defenders collect?	Web access logs, JCE profile records, JCE configuration, suspicious PHP files in	Compromise assessment and eradication.

	writable web paths, and authentication/admin changes.	
How should manufacturing-aligned organizations respond?	Treat public Joomla portals and supplier-facing sites as potential initial-access surfaces that may bridge into business workflows.	Risk owner communication and segmentation review.

Scope note: this report is source-backed by public CISA, vendor, media, and research reporting. Lost Boys Cyber did not exploit or lab-reproduce CVE-2026-48907 for this report. Detection and hunting content is therefore written as operational guidance derived from disclosed mechanics and observed artifact descriptions, not from proprietary telemetry.

3. Source Review and Confidence

Source	Contribution	Confidence	Notes
CISA KEV catalog and 2026-06-16 alert	Confirms active exploitation, affected product naming, CWE-284, required action, and 2026-06-19 due date.	High	Primary government source for exploitation status and federal prioritization.
Widget Factory / JCE advisory and changelog	Confirms 2.9.99.5 fixed unauthenticated editor profile upload; 2.9.99.6 adds broader hardening; vendor states exploitation is active and patching does not clean compromise artifacts.	High	Primary vendor source for remediation and artifact review guidance.
The Hacker News intake article	Summarizes KEV addition, CVE, affected versions 1.0.0 through 2.9.99.4, and patched version 2.9.99.5.	Medium	Useful secondary reporting; not treated as canonical where primary sources are available.
mySites.guru JCE profile hack reporting	Describes observed rogue profiles, webshell locations, attacker naming patterns, and cleanup considerations.	Medium-High	Vendor/defender telemetry; valuable for artifact hypotheses but environment-specific.
YesWeHack technical write-up	Provides endpoint and exploit-flow analysis for the unauthenticated profile import path and proof-of-concept context.	Medium	Technical analysis supports detection design; defenders should avoid reproducing exploit outside authorized lab settings.

Overall confidence is High that CVE-2026-48907 is actively exploited and materially raises risk for exposed Joomla/JCE deployments. Confidence is Medium for specific attacker infrastructure, victimology, and campaign attribution because public sources have not attributed exploitation to a named actor and CISA lists known ransomware use as Unknown.

4. Key Findings

Finding	Severity	Confidence	Defensive implication
CVE-2026-48907 enables unauthenticated manipulation of JCE editor profiles that can lead to PHP upload and	Critical	High	Internet-facing vulnerable instances should be patched or isolated immediately.

execution.			
JCE 1.0.0 through 2.9.99.4 are reported affected; 2.9.99.5 patches the CVE, while 2.9.99.6 is the vendor-recommended hardened target.	Critical	High	Patch targets should prefer 2.9.99.6, not merely the first fixed build, where platform compatibility allows.
CISA added the vulnerability to KEV on 2026-06-16 with a 2026-06-19 required action date for covered systems.	High	High	This should trigger emergency vulnerability management and executive visibility.
Updating JCE closes the entry point but does not remove rogue profiles, webshells, or other post-exploitation artifacts.	High	High	Remediation requires compromise assessment, not patch-only closure.
Public reporting indicates rogue profiles may use generated names, high-priority ordering, public/anonymous targeting, PHP-capable upload settings, and dropped files in writable Joomla directories.	High	Medium-High	Detection should combine HTTP endpoint monitoring, database/profile inspection, and file-system scanning.

5. Threat Context

Joomla remains common in public websites, small business portals, municipal and education sites, supplier portals, intranet-like extranets, and operational support pages that may not receive the same patch urgency as flagship applications. A critical pre-authentication plugin flaw can therefore become an attractive opportunistic initial-access vector even when the affected site is not a primary business application.

CVE-2026-48907 is especially concerning because it sits at the intersection of three attacker-friendly conditions:

- The vulnerable component is a broadly deployed editor extension rather than a niche custom plugin.
- The exposed behavior is pre-authentication and does not depend on public user registration being enabled.
- The exploitation outcome can cross from configuration manipulation into executable PHP content on the web server.

Public vendor and defender reporting describes an attack pattern in which an attacker imports a permissive JCE editor profile, configures upload behavior to allow script-capable extensions, and then drops webshell content into writable Joomla paths. Reported profile and file-system indicators include machine-generated profile names such as a capital J followed by six digits, suspicious profile labels such as Pwned or RCE via JCE, very negative ordering values that force profile precedence, upload allow-lists containing php or phtml, disabled MIME validation, and files with webshell behaviors such as eval/gzinflate/base64_decode or shell_exec command handlers.

For manufacturing-aligned organizations, the primary risk is usually not that Joomla directly controls OT. The realistic risk is that a compromised CMS becomes a beachhead for credential theft, supplier impersonation, malicious content hosting, phishing infrastructure, webshell persistence, or lateral movement into adjacent business services. Public web compromise also creates brand, customer trust, and incident response burdens independent of deeper network impact.

Exposure details

Exposure pattern	Risk	Defensive question
Public Joomla site with JCE <= 2.9.99.4	Highest risk; vulnerable to pre-authentication exploitation.	Is the site patched to 2.9.99.6 and have logs/profile tables been reviewed?
Public Joomla site updated after 2026-06-	Entry point may be closed but prior	Was there an access-log and file-integrity

03	compromise remains possible.	review before closure?
Internal Joomla site reachable by VPN, partners, or third parties	Lower exposure but still relevant if broad access exists.	Are partner/VPN source ranges logged and monitored for exploit endpoint requests?
Decommissioned or forgotten Joomla instance	High latent risk due to unmanaged plugins and weak monitoring.	Does external attack-surface management find unknown Joomla/JCE deployments?
Sites unable to move beyond older PHP/Joomla baselines	Persistent risk due to compatibility constraints.	Can the vendor patch be applied, or should the site be isolated or retired?

6. Detection and Hunting

Detection should be layered across HTTP access logs, Joomla/JCE profile state, file integrity monitoring, EDR where available, and web-server process telemetry. A single clean signal is not sufficient: an attacker may import a malicious profile, stage an XML or PHP file, remove some artifacts, and retain access through a renamed webshell.

Detection logic summary

Signal	Telemetry source	Analytic goal	Priority
Request to /index.php?option=com_jce&task=profiles.import without authenticated admin context	Web access logs, WAF, reverse proxy	Identify exploit attempts or successful profile import.	Critical
New or modified JCE editor profile with generated name, negative ordering, public user type, php/phtml upload extensions, or disabled MIME validation	Joomla database/config export, admin review	Identify rogue profile persistence and upload enablement.	Critical
PHP or mixed-extension files in images, media, tmp, media/system/js, or libraries/joomla	File integrity monitoring, EDR, web-host scan	Identify uploaded webshells or droppers.	Critical
Web server process spawning shell utilities or network tooling	EDR, auditd, Sysmon for Linux, web-host telemetry	Identify webshell command execution.	High
POST traffic to newly created PHP/XML-PHP files in writable paths	Web access logs, WAF	Identify active webshell use.	High
Unusual Joomla administrator account creation or plugin/template modification after exploit window	Joomla audit logs, database review	Identify post-exploitation persistence and privilege abuse.	High

Sigma: suspicious JCE profile import over web logs

```

title: Joomla JCE Unauthenticated Profile Import Attempt CVE-2026-48907
id: 1db7f84c-6d33-4cc9-8cf8-8fb3383fb907
status: experimental
description: Detects HTTP requests to the Joomla Content Editor profile import task associated with CVE-2026-48907 exploitation attempts.
author: Lost Boys Cyber
date: 2026-06-17

```

```

references:
- https://www.cisa.gov/news-events/alerts/2026/06/16/cisa-adds-one-known-exploited-vulnerability-catalog
- https://www.joomlacontenteditor.net/news/jce-security-update-and-a-free-patch-for-older-sites
logsource:
  category: webserver
detection:
  selection_uri:
    cs-uri-query|contains|all:
      - 'option=com_jce'
      - 'task=profiles.import'
  selection_uri_path:
    cs-uri-stem|endswith: '/index.php'
  condition: selection_uri and selection_uri_path
fields:
- src_ip
- cs-method
- cs-uri-stem
- cs-uri-query
- sc-status
- cs-user-agent
falsepositives:
- Legitimate administrator profile import activity, which should be rare and should occur from known admin sessions and source ranges.
level: high

```

KQL: Microsoft Defender hunt for webshell execution from web server process

```

// Hunt for suspicious shell execution from web-serving processes after possible JCE exploitation.
let lookback = 30d;
let webParents = dynamic(['apache2','httpd','nginx','php-fpm','php-cgi','lsphp']);
let suspiciousChildren =
dynamic(['sh','bash','dash','zsh','cmd','powershell','python','perl','curl','wget','nc','ncat','socat']
);
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where InitiatingProcessFileName in~ (webParents)
| where FileName in~ (suspiciousChildren)
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine,
InitiatingProcessCommandLine, AccountName, ReportId
| order by Timestamp desc

```

KQL: writable Joomla path webshell artifact hunt

```

// Review PHP-capable files written under common Joomla writable paths.
let lookback = 30d;
DeviceFileEvents
| where Timestamp > ago(lookback)
| where FolderPath has_any ('/images/', '/media/', '/tmp/', '/media/system/js/', '/libraries/joomla/')
| where FileName matches regex @'.*\. (php|phtml|php[0-9]?|xml\.php|php\.xml)$'
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, SHA256, InitiatingProcessFileName,
InitiatingProcessCommandLine, AccountName
| order by Timestamp desc

```

Splunk: web access log hunt for exploit endpoint and webshell follow-on traffic

```

index=web sourcetype IN (access_combined,apache:access,nginx:access)
earliest=-30d
(
  (uri_path="/index.php" uri_query="*option=com_jce*" uri_query="*task=profiles.import*")
  OR uri_path IN ("*/images/*.php", "*/media/*.php", "*/tmp/*.php", "*/media/system/js/*.php",
  "*/libraries/joomla/*.php")
  OR uri_path="*.xml.php"
)
| stats count min(_time) as first_seen max(_time) as last_seen values(status) as statuses
values(http_method) as methods values(useragent) as user_agents by src_ip, host, uri_path, uri_query
| convert ctime(first_seen) ctime(last_seen)

```

| sort - count

File-system triage commands for Linux Joomla hosts

Run only on owned systems. Preserve copies and timestamps before deleting suspected evidence.

```
# Locate PHP-capable files in directories that should primarily hold static content.
find /var/www -type f \
  \( -path '*/images/*' -o -path '*/media/*' -o -path '*/tmp/*' -o -path '*/media/system/js/*' -o -path
  '*/libraries/joomla/*' \) \
  \( -iname '*.php' -o -iname '*.phpml' -o -iname '*.php[0-9]' -o -iname '*.xml.php' -o -iname
  '*.php.xml' \) \
  -printf '%TY-%m-%d %TH:%TM:%TS %u %g %m %p\n' | sort

# Search for common webshell primitives in suspicious Joomla paths.
grep -RInE 'eval\s*\(|gzinflate\s*\(|base64_decode\s*\(|shell_exec\s*\(|system\s*\(|passthru\s*\(|
assert\s*\(' \
  /var/www/*/images /var/www/*/media /var/www/*/tmp /var/www/*/media/system/js
/var/www/*/libraries/joomla 2>/dev/null

# Review exploit endpoint requests in Apache-style logs.
zgrep -hE 'option=com_jce.*task=profiles\.import|task=profiles\.import.*option=com_jce'
/var/log/apache2/*access* /var/log/httpd/*access* 2>/dev/null
```

7. Recommendations

Priority	Owner	Action	Target timeline	Success criteria
Critical	Web / CMS owner	Inventory all Joomla sites and identify installed JCE versions.	Same day	Complete list of public and internal Joomla assets with JCE version and exposure state.
Critical	Web / CMS owner	Upgrade JCE to 2.9.99.6 where supported; if not possible, apply vendor patch/mitigation and plan platform upgrade.	Same day to 24 hours	No exposed site remains on JCE 1.0.0 through 2.9.99.4 without compensating isolation.
Critical	Security operations	Review access logs for profile import endpoint requests since at least 2026-06-01; retain raw logs for investigation.	Same day	Exploit attempts and possible successful requests are documented by source IP, timestamp, status, and user agent.
Critical	Incident response	Inspect JCE profiles for unauthorized entries, script-capable uploads, negative ordering, public scope, and disabled MIME validation.	Same day	Rogue or suspicious profile state is exported, preserved, and remediated.
High	Incident response	Hunt for webshells and droppers in writable Joomla paths; preserve suspected artifacts before deletion.	24-48 hours	Suspicious files are hashed, reviewed, removed, and used to scope compromise.
High	Identity / platform	Rotate Joomla administrator credentials, hosting	24-48 hours after confirmation	Credentials potentially exposed through webshell access are

		control panel credentials, database credentials, and API secrets if compromise is confirmed.		invalidated.
High	Infrastructure	Isolate legacy Joomla sites that cannot meet supported PHP/Joomla/JCE requirements.	7 days	Unsupported systems are behind access controls, WAF rules, or decommissioned.
Medium	Security engineering	Deploy detections for exploit endpoint access, webshell file writes, and web process command execution.	7 days	Detections generate actionable alerts with runbooks and ownership.
Medium	Governance	Add Joomla/JCE to recurring external attack-surface and plugin lifecycle reviews.	30 days	CMS plugin inventory is refreshed and aged vulnerable extensions are escalated.

Containment guidance for confirmed compromise:

- Do not only delete the visible webshell. Export and preserve the rogue profile, suspicious files, web logs, and modification timestamps first.
- Assume webroot integrity is untrusted until compared against a clean backup or redeployed from source.
- Restore from a backup known to predate the first exploit endpoint request when feasible, then patch before reconnecting the system.
- Review administrator accounts, templates, plugins, scheduled tasks, cron jobs, .htaccess files, and unexpected outbound connections.
- If the Joomla host shares credentials with other systems, rotate those credentials and assess lateral movement risk.

8. References

- [1] CISA, “CISA Adds One Known Exploited Vulnerability to Catalog,” 2026-06-16. <https://www.cisa.gov/news-events/alerts/2026/06/16/cisa-adds-one-known-exploited-vulnerability-catalog>
- [2] CISA Known Exploited Vulnerabilities catalog entry for CVE-2026-48907. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [3] Widget Factory / Joomla Content Editor, “JCE security update, and a free patch for older sites,” 2026-06-12. <https://www.joomlacontenteditor.net/news/jce-security-update-and-a-free-patch-for-older-sites>
- [4] Widget Factory / Joomla Content Editor changelog, JCE Editor 2.9.99.5 and 2.9.99.6. <https://www.joomlacontenteditor.net/support/changelog/editor>
- [5] The Hacker News, “CISA Warns of Actively Exploited Joomla JCE Flaw Allowing PHP Code Execution,” 2026-06-17. <https://thehackernews.com/2026/06/cisa-warns-of-actively-exploited-joomla.html>
- [6] mySites.guru, “JCE 2.9.99.5 Security Update,” 2026-06-03. <https://mysites.guru/blog/jce-pro-2-9-99-5-security-update/>
- [7] mySites.guru, “Find and Fix the JCE Profiles Hack,” 2026-06-17. <https://mysites.guru/blog/finding-every-site-running-a-vulnerable-jce/>
- [8] YesWeHack, “CVE-2026-48907: Unauthenticated RCE in the Joomla Content Editor extension,” 2026-06-12. <https://www.yeswehack.com/news/rce-joomla-content-editor-extension>
- [9] CVE Program record for CVE-2026-48907. <https://www.cve.org/CVERecord?id=CVE-2026-48907>
- [10] NVD record for CVE-2026-48907. <https://nvd.nist.gov/vuln/detail/CVE-2026-48907>